

## PRODUCT REQUIREMENTS DOCUMENT

# CONTINUOUS ASSURANCE (IT)

Keyakinan berkelanjutan atas postur keamanan eksternal — dengan validasi manusia, penutupan terverifikasi, dan keluaran untuk auditor, asuransi, serta sponsor PE.

---

**Produk** · Atumcell Continuous Assurance (IT)

**Versi dokumen** · 1.0

**Status** · Draft untuk review lead / product

**Tanggal** · 10 September 2026

**Penulis** · Ilham Abdullah · Atumcell

**Audiens** · Leadership, Product, Engineering, Delivery / Pentest

**Artefak terkait** · Prototype ca-app · Mock-up HTML · Skrip narasi

## 1. RINGKASAN EKSEKUTIF

---

Continuous Assurance (IT) adalah produk Atumcell untuk menjawab celah antara **scan otomatis terus-menerus** (banyak noise) dan **pentest berkala** (dalam, tapi cepat kedaluwarsa). Produk memantau attack surface eksternal secara berkelanjutan, memvalidasi temuan penting dengan manusia, dan menutup temuan hanya setelah retest — lengkap dengan **sertifikat penutupan bertanggung**.

**Bukan** compliance automation ala Vanta/Drata. **Bukan** security rating murni ala Bitsight. **Ya:** continuous external monitoring + human validation + verified closure + portofolio PE + binder asuransi.

Analog terdekat di pasar: **Rapid7 Vector Command** (continuous recon + human red team). Yang tidak ditiru: Exposure Command Ultimate (CNAPP, agent, ratusan konektor).

## 2. MASALAH & PELUANG

---

### 2.1 Masalah pelanggan

1. **Noise otomatis** — alat EASM/scanner menghasilkan banyak temuan tanpa bukti eksploitasi.
2. **Assurance kedaluwarsa** — laporan pentest tahunan tidak merefleksikan perubahan attack surface mingguan.
3. **Klaim berlebihan** — “sudah dipantau” sering disamakan dengan “sudah aman”, tanpa memisahkan tervalidasi vs belum diperiksa.
4. **Bukti sulit dipakai** — auditor, underwriter, dan IC PE butuh artefak bertanggung, bukan screenshot scan.
5. **Sponsor PE buta spot** — sulit roll-up risiko lintas portofolio perusahaan.

### 2.2 Peluang Atumcell

- Keahlian pentest / red team Atumcell menjadi diferensiator inti (bukan add-on).
- Posisi mid-market & PE: lebih fokus dari platform CTEM enterprise-heavy.
- Sinergi potensial dengan AtumScan / AtumScreen / SpoofCheck (keputusan terbuka).

## 3. TUJUAN PRODUK

---

### 3.1 Goals

1. Memberikan **assurance yang bisa dibuktikan** atas eksposur eksternal.
2. Memisahkan secara eksplisit: human-validated / automated / unscanned.
3. Menghubungkan monitoring kontinu dengan siklus pentest Atumcell.
4. Menghasilkan artefak penutupan (sertifikat) dan laporan untuk auditor, asuransi, PE.
5. Menyediakan roll-up portofolio untuk sponsor PE + pipeline due diligence.

### 3.2 Non-goals (v1)

- Platform compliance penuh (kebijakan, HR, vendor risk ala Vanta).

- CNAPP / agent endpoint / 500+ cloud connector.
- Vulnerability management internal penuh (VM agent-based) sebagai fokus utama.
- Menggantikan seluruh stack XDR/SIEM.

## 4. PERSONAS & BUYER

| PERSONA                                  | KEBUTUHAN UTAMA                                                       | KESUKSESAN                                           |
|------------------------------------------|-----------------------------------------------------------------------|------------------------------------------------------|
| <b>CISO / Head of IT</b> (mid-market)    | Prioritas nyata, kurangi false positive, bukti untuk board & asuransi | Skor & critical turun; sertifikat siap renewal       |
| <b>Security / AppSec engineer</b>        | Antrian kerja jelas, SLA, retest cepat                                | Kanban bergerak; retest tidak menghambat             |
| <b>Sponsor PE / Operating partner</b>    | Roll-up portofolio, agenda IC, DD target                              | Matriks risiko & perusahaan berisiko terlihat        |
| <b>Underwriter / auditor</b> (secondary) | Bukti teknis bertanggung, binder                                      | Pack bukti bisa dilampirkan tanpa penjelasan panjang |

**Keputusan terbuka:** buyer utama — CISO mid-market, sponsor PE, atau keduanya? PRD ini merancang agar keduanya dilayani, dengan company tenant sebagai unit default dan PE Portfolio sebagai modul sponsor.

## 5. POSITIONING & KOMPETITOR

| TIPE             | CONTOH                          | KEKUATAN MEREKA            | CELAH ATUMCELL                                             |
|------------------|---------------------------------|----------------------------|------------------------------------------------------------|
| Security ratings | Bitsight, SecurityScorecard     | Skor & grade eksekutif     | Validasi exploit manusia jarang                            |
| EASM / CTEM      | UpGuard, CyCognito, Halo        | Inventaris surface         | Klaim “otomatis = selesai”                                 |
| PTaaS            | Cobalt, Synack                  | Manusia + retest           | Engagement, kurang continuous + PE                         |
| Compliance       | Vanta, Drata                    | Kebijakan & connector      | Lemah di bukti teknis eksternal tervalidasi                |
| Rapid7           | Vector Command (+ Exposure Cmd) | Continuous red team + CTEM | Enterprise-heavy; sertifikat & PE mid-market kurang tonjol |

### 5.1 Diferensiator wajib di produk

1. Label **human-validated** eksplisit di setiap temuan.
2. **Sertifikat penutupan** bertanggung setelah retest.
3. **Siklus pengujian** menyambung monitoring ↔ pentest.
4. **Portofolio PE** + due diligence.
5. **Binder asuransi** sebagai laporan pembeda.

## 6. PRINSIP PRODUK

---

1. **Prove, don't claim** — jangan menyamakan scanned dengan secured.
2. **Human in the loop untuk yang penting** — critical / KEV / high-impact wajib jalur validasi.
3. **Closure is a verb** — tutup hanya lewat verifikasi, bukan drag ke “done”.
4. **Artefak > dashboard** — output harus bisa dilampirkan ke pihak ketiga.
5. **Agentless-first (v1)** — fokus eksternal; perluasan internal opsional kemudian.
6. **UI jujur** — coverage gap (unscanned) ditampilkan terang-terangan.

## 7. RUANG LINGKUP

---

### 7.1 In scope — MVP / v1

- Discovery attack surface eksternal (DNS, CT, IP range, cloud bucket publik, related domain).
- Finding management dengan severity, KEV, SLA, owner.
- Antrian & kuota human validation + emergent KEV queue.
- Remediation kanban + verified closure + sertifikat.
- Testing cycle: usulan scope, kuota, riwayat uji.
- Evidence readiness sempit (CIS teknis, SOC2 CC teknis, ISO Annex A teknis, asuransi).
- Reports multi-audiens termasuk insurance binder.
- PE Portfolio: KPI, daftar perusahaan, matriks, DD pipeline.
- Multi-tenant company view; tema light/dark.

### 7.2 Out of scope — v1

- Agent / EDR / cloud posture penuh (CSPM/CNAPP).
- Policy library & employee security training.
- Vendor risk management penuh.
- Mobile app native.
- OT / ICS Continuous Assurance (produk terpisah jika ada).

## 8. JOURNEY PENGGUNA UTAMA

---

### 8.1 Assurance cycle (inti)

**Discover → Validate → Prioritize → Remediate**

1. **Discover** — sweep menemukan aset & perubahan surface.
2. **Validate** — manusia mengonfirmasi/menolak temuan otomatis; escalate bila perlu.
3. **Prioritize** — critical + KEV + dampak bisnis jadi antrian kerja.
4. **Remediate** — perbaikan → retest → sertifikat penutupan.

### 8.2 Journey CISO (mingguan)

1. Buka Overview: skor, critical aktif, % human-validated.
2. Review KEV / emergent queue.

3. Generate laporan board atau binder asuransi.

### 8.3 Journey engineer

1. Filter findings pending / critical.
2. Buka detail → bukti & langkah reproduksi.
3. Minta validasi atau tandai fixed → request retest.
4. Gerakkan kartu di Remediation; tutup via verifikasi.

### 8.4 Journey PE sponsor

1. Buka PE Portfolio: KPI dana, perusahaan berisiko.
2. Filter / klik matriks risiko.
3. Review DD targets & rekomendasi.

## 9. PERSYARATAN FUNGSIONAL

---

Prioritas: **P0** wajib MVP · **P1** penting · **P2** later

### 9.1 Overview / Dashboard

| ID    | REQUIREMENT                                                                          | PRI |
|-------|--------------------------------------------------------------------------------------|-----|
| OV-01 | Tampilkan skor eksposur, grade, delta periode, last sweep                            | P0  |
| OV-02 | Tampilkan metrik: % human-validated, critical aktif, open findings, assets monitored | P0  |
| OV-03 | Pisahkan coverage: human validated / automated / unscanned                           | P0  |
| OV-04 | Strip siklus Discover→Validate→Prioritize→Remediate dengan deep-link                 | P0  |
| OV-05 | Daftar priority findings + activity feed                                             | P0  |
| OV-06 | Tren skor & findings (12 minggu)                                                     | P1  |

### 9.2 Attack Surface

| ID    | REQUIREMENT                                                                              | PRI |
|-------|------------------------------------------------------------------------------------------|-----|
| AS-01 | Inventaris aset: host, tipe, sumber discovery, tech, ports, status, risk, findings count | P0  |
| AS-02 | Status aset: verified / auto / unscanned wajib terlihat                                  | P0  |
| AS-03 | Filter, search, export CSV                                                               | P0  |
| AS-04 | Sumber discovery: DNS, CT, IP range, cloud, WHOIS pivot, scope pentest                   | P1  |
| AS-05 | Notifikasi aset baru (feed / list newly discovered)                                      | P1  |

### 9.3 Findings

| ID    | REQUIREMENT                                                             | PRI |
|-------|-------------------------------------------------------------------------|-----|
| FD-01 | Daftar findings dengan severity, KEV flag, validation badge, SLA, owner | P0  |
| FD-02 | Filter severity / validation / KEV / search                             | P0  |
| FD-03 | Detail: impact bisnis, evidence, steps reproduksi, remediation advice   | P0  |
| FD-04 | Aksi: Request human validation; Mark fixed → request retest; Assign     | P0  |
| FD-05 | Validation status: verified   pending   auto                            | P0  |
| FD-06 | Metadata validator, validatedAt, method                                 | P1  |

### 9.4 Human validation & KEV

| ID    | REQUIREMENT                                                          | PRI |
|-------|----------------------------------------------------------------------|-----|
| HV-01 | Kuota validasi manusia per periode; request mengurangi kuota         | P0  |
| HV-02 | Retest setelah remediasi tidak memotong kuota validasi               | P0  |
| HV-03 | Modal / queue emergent KEV dengan SLA ketat (mis. < 24 jam)          | P0  |
| HV-04 | Hasil validasi: confirm exploit / false positive / escalate severity | P0  |
| HV-05 | Activity feed mencatat aksi validasi & penutupan                     | P1  |

### 9.5 Remediation & Verification

| ID    | REQUIREMENT                                                                                       | PRI |
|-------|---------------------------------------------------------------------------------------------------|-----|
| RM-01 | Kanban: New → Assigned → In progress → Awaiting verification → Closed verified                    | P0  |
| RM-02 | Drag-and-drop antar kolom (kecuali aturan penutupan)                                              | P0  |
| RM-03 | <b>Hard rule:</b> masuk Closed verified hanya lewat alur verifikasi (bukan drag bebas)            | P0  |
| RM-04 | Verifikasi berhasil menerbitkan sertifikat penutupan (cert ID, hash/metadata, tanggal, validator) | P0  |
| RM-05 | Daftar closed findings + tautan sertifikat                                                        | P0  |
| RM-06 | SLA pill (on track / soon / late) di kartu                                                        | P1  |

## 9.6 Testing Cycle

| ID    | REQUIREMENT                                                          | PRI |
|-------|----------------------------------------------------------------------|-----|
| TC-01 | Tampilkan next pentest / window pengujian                            | P0  |
| TC-02 | Usulan scope dari monitoring (proposed targets + alasan + prioritas) | P0  |
| TC-03 | Riwayat pengujian (tipe, scope, findings, status, tanggal)           | P0  |
| TC-04 | Aturan scope & test rules (modal konfigurasi)                        | P1  |
| TC-05 | Request pengujian ad-hoc ke tim Atumcell                             | P1  |

## 9.7 Evidence Readiness

| ID    | REQUIREMENT                                                                                                       | PRI |
|-------|-------------------------------------------------------------------------------------------------------------------|-----|
| EV-01 | Progress % per kerangka teknis sempit (CIS IG1, SOC2 CC teknis, ISO A teknis, NIS2/DORA subset, insurance binder) | P0  |
| EV-02 | Pemetaan kontrol → bukti yang bisa dibuktikan dari luar / dari CA                                                 | P1  |
| EV-03 | Export evidence pack (PDF/ZIP)                                                                                    | P1  |
| EV-04 | UI menyatakan batas: bukan compliance platform penuh                                                              | P0  |

## 9.8 Reports

| ID    | REQUIREMENT                                                                              | PRI |
|-------|------------------------------------------------------------------------------------------|-----|
| RP-01 | Template laporan multi-audien: executive, technical, PE IC, insurance underwriter binder | P0  |
| RP-02 | Insurance binder ditandai sebagai diferensiator                                          | P0  |
| RP-03 | Riwayat laporan (periode, recipients, format, created)                                   | P1  |
| RP-04 | Generate / download (async OK di v1)                                                     | P1  |

## 9.9 PE Portfolio

| ID    | REQUIREMENT                                                        | PRI |
|-------|--------------------------------------------------------------------|-----|
| PE-01 | KPI dana: #companies, avg score, critical open, % verified         | P0  |
| PE-02 | Daftar perusahaan dengan filter sektor/tier/risiko                 | P0  |
| PE-03 | Attention / IC agenda untuk perusahaan berisiko                    | P0  |
| PE-04 | Matriks risiko interaktif (klik sel → filter)                      | P1  |
| PE-05 | Due diligence pipeline (stage, grade, score, finding, rekomendasi) | P0  |
| PE-06 | Drill-down ke tenant perusahaan                                    | P1  |

## 9.10 Platform / lintas modul

| ID    | REQUIREMENT                                                     | PRI |
|-------|-----------------------------------------------------------------|-----|
| PL-01 | Tenant switcher (perusahaan)                                    | P0  |
| PL-02 | AuthN/AuthZ role: Admin, Analyst, Validator, Viewer, PE Sponsor | P0  |
| PL-03 | Theme light / dark                                              | P1  |
| PL-04 | Toast / notifikasi aksi penting                                 | P1  |
| PL-05 | Audit log aksi validasi & penutupan                             | P0  |
| PL-06 | Branding Atumcell (logo resmi + wordmark Assurance)             | P0  |

## 10. PERSYARATAN NON-FUNGSIONAL

| AREA               | REQUIREMENT                                                                                        |
|--------------------|----------------------------------------------------------------------------------------------------|
| Keamanan           | Enkripsi in-transit (TLS); data tenant terisolasi; least privilege; rahasia tidak di client bundle |
| Privasi            | Evidence & sertifikat hanya untuk role berwenang; retensi dapat dikonfigurasi                      |
| Kinerja            | UI daftar < 2s untuk 10k assets / 50k findings (pagination/virtualisasi)                           |
| Ketersediaan       | Target 99.5% untuk portal; sweep discovery dapat delayed tanpa downtime portal                     |
| Observabilitas     | Log sweep, validation SLA breach, job retest                                                       |
| Aksesibilitas      | Kontras memadai light/dark; kontrol keyboard untuk aksi utama                                      |
| Internasionalisasi | UI produk bahasa Inggris (v1); dokumen internal boleh ID                                           |
| Kepatuhan delivery | Scope rules mencegah aksi destruktif di validasi                                                   |

## 11. MODEL DATA (TINGKAT TINGGI)

| ENTITAS          | ATRIBUT KUNCI                                                                                                  |
|------------------|----------------------------------------------------------------------------------------------------------------|
| Tenant / Company | name, domain, sector, sponsor, lastSweep, nextPentest                                                          |
| Asset            | host, type, source, tech, ports, status, risk, lastSeen, findingsCount                                         |
| Finding          | id, title, asset, severity, kev, validation, validator, method, SLA, owner, CVSS, evidence, steps, remediation |
| BoardCard        | findingId, column, assignee                                                                                    |
| Certificate      | certId, findingId, closedAt, validator, openDays, integrity hash                                               |
| ValidationQuota  | period, remaining, burned                                                                                      |
| TestEngagement   | name, type, scope, findings, status, date                                                                      |
| Report           | template, period, recipients, format, createdAt                                                                |
| PortfolioFund    | name, companies[], matrix, dueDiligence[]                                                                      |

## 12. ATURAN BISNIS KRITIS

1. Temuan tidak boleh berstatus “Closed verified” tanpa retest lulus oleh validator berwenang.
2. Request human validation mengurangi kuota; retest remediasi tidak mengurangi kuota.
3. KEV / emergent masuk antrian prioritas dengan SLA terpisah.
4. UI wajib menampilkan aset unscanned — tidak boleh menyembunyikan coverage gap.
5. Sertifikat memuat identitas finding, tanggal, validator, dan penanda integritas.
6. Laporan asuransi hanya menyertakan temuan/penutupan yang memenuhi ambang bukti (configurable).

## 13. METRIK KEBERHASILAN

| METRIK                                 | DEFINISI                                      | TARGET ARAH (AWAL)         |
|----------------------------------------|-----------------------------------------------|----------------------------|
| Time-to-validate                       | Waktu dari pending → verified/rejected        | Turun; KEV < 24 jam        |
| % human-validated (open critical/high) | Proporsi temuan prioritas tervalidasi manusia | ≥ 80%                      |
| False positive rejection rate          | Auto findings ditolak saat validasi           | Terukur & tren turun noise |
| Verified closure rate                  | Closed dengan sertifikat / total closed       | 100% untuk critical        |
| Mean time-to-close (critical)          | First seen → certified close                  | Turun per kuartal          |
| Binder readiness                       | % kelengkapan evidence asuransi               | ≥ 90% menjelang renewal    |
| PE adoption                            | # dana / perusahaan aktif di Portfolio        | Sesuai GTM                 |

## 14. ROADMAP USULAN

| FASE                                             | FOKUS                                                                                     | HASIL                           |
|--------------------------------------------------|-------------------------------------------------------------------------------------------|---------------------------------|
| <b>Phase 0 — Discovery</b><br>Selesai / berjalan | Riset, positioning, prototype interaktif ca - app                                         | PRD + demo untuk alignment lead |
| <b>Phase 1 — MVP</b>                             | Tenant tunggal, discovery + findings + validation queue + kanban + sertifikat + 2 laporan | Pilot pilot mid-market          |
| <b>Phase 2 — Assurance ops</b>                   | Kuota & SLA production, evidence pack, insurance binder, audit log                        | Siap underwriter & auditor      |
| <b>Phase 3 — PE</b>                              | Multi-company portfolio, DD pipeline, IC pack                                             | GTM sponsor PE                  |
| <b>Phase 4 — Scale</b>                           | Integrasi ticketing (Jira), SIEM webhook, API publik, perluasan discovery                 | Operasi skala                   |

## 15. ASUMSI, RISIKO, KEPUTUSAN TERBUKA

### 15.1 Asumsi

- Tim pentest Atumcell dapat menopang SLA validasi untuk jumlah tenant pilot.
- Pelanggan menerima model agentless eksternal sebagai titik masuk.
- Buyer menghargai sertifikat penutupan lebih dari skor generik.

## 15.2 Risiko

| RISIKO                             | DAMPAK           | MITIGASI                                     |
|------------------------------------|------------------|----------------------------------------------|
| Kapasitas manusia tidak scale      | SLA jebol        | Kuota, prioritas KEV, tiering paket          |
| Terkesan “Bitsight clone”          | Komoditisasi     | Tonjolkan validation label + sertifikat + PE |
| Scope creep ke CNAPP               | Burn engineering | Non-goals ketat di PRD                       |
| Duplikasi produk Atumcell existing | Kanibalisme      | Klarifikasi payung vs produk baru            |

## 15.3 Keputusan yang dibutuhkan dari lead

1. Buyer utama: CISO mid-market, PE, atau keduanya?
2. Hubungan dengan AtumScan / AtumScreen / SpoofCheck?
3. Batas v1: eksternal agentless saja, atau ikut internal/VM?
4. Kedalaman human validation: triage mingguan, continuous red team, atau hybrid (seperti Vector Command Advanced)?

## 16. STATUS PROTOTYPE SAAT INI

Prototype React (ca - app) sudah mencakup modul:

- Overview, Attack Surface, Findings (+ detail), Remediation (drag-drop + sertifikat), Testing Cycle, Evidence, Reports, PE Portfolio, Compare vs Rapid7
- State interaktif: request validation, KEV modal, verify & close, theme light/dark, branding logo Atumcell
- Data demo fiktif: tenant Northwind Logistics / sponsor Meridian Capital Partners

Prototype = alat alignment, bukan spesifikasi final implementasi backend.

## 17. LAMPIRAN A — GLOSARIUM

| ISTILAH          | ARTI                                            |
|------------------|-------------------------------------------------|
| EASM             | External Attack Surface Management              |
| CTEM             | Continuous Threat Exposure Management           |
| PTaaS            | Penetration Testing as a Service                |
| KEV              | Known Exploited Vulnerability (CISA)            |
| Human-validated  | Temuan dikonfirmasi/ditolak oleh tester manusia |
| Verified closure | Penutupan setelah retest lulus + sertifikat     |
| Insurance binder | Paket bukti untuk underwriter asuransi siber    |

## 18. LAMPIRAN B — SEJARAH DOKUMEN

| VERSI | TANGGAL     | CATATAN                                                 |
|-------|-------------|---------------------------------------------------------|
| 1.0   | 10 Sep 2026 | Draft awal dari riset + prototype ca-app + skrip narasi |

— Akhir dokumen PRD Continuous Assurance (IT) v1.0 —